

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)

Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Lab Assignment: Compliance Management and Reporting

Lab Objectives:

This lab assignment is designed to help you:

- Understand compliance management processes and documentation requirements
- Develop skills in creating compliance documentation and reports
- Apply compliance monitoring and measurement techniques
- Gain practical experience in compliance program evaluation

Instructions:

Complete all parts of this lab assignment. Submit your completed document to your instructor by the due date. All answers should be typed directly into this document.

Part 1: Compliance Documentation Development (30 points)

For this exercise, you will develop key compliance documentation for a fictional organization. Imagine you are the Compliance Officer for TechSecure Solutions, a mid-sized software development company that handles sensitive customer data and is subject to various regulations including GDPR and industry standards like ISO 27001.

Create the following compliance documentation:

1. Develop a Compliance Policy Statement (5-7 sentences) that outlines TechSecure Solutions' commitment to regulatory compliance. Include the purpose, scope, key principles, and responsibilities. (10 points)

At TechSecure Solutions, compliance is an important part of how we protect our customers, employees and the organization. The purpose of this policy is to ensure that our business activities follow applicable laws, regulations and standards, including GDPR and ISO/IEC 27001, especially because we handle sensitive customer information. This policy applies to all employees, management, contractors and third parties who access company systems or

process information on behalf of TechSecure Solutions. Our approach is based on accountability, ethical behavior, protection of sensitive information, transparency and continuous improvement. Management is responsible for ensuring that compliance is considered when making business decisions and that enough resources are provided to support the compliance programme. The Compliance Officer will monitor compliance requirements, advise the organization and report significant issues, while employees are expected to follow policies and report any suspected violations. From what I have learned, compliance works better when everyone understands that it is a shared responsibility rather than something left only to the Compliance, Legal or IT teams.

2. Create a Compliance Monitoring Plan that includes at least five specific monitoring activities, their frequency, responsible parties, and how results will be documented. Present this in a table format. (10 points)

From what I have learned, having compliance policies in place is not enough; an organisation also needs to regularly check whether employees and departments are following them. At TechSecure Solutions, the compliance monitoring plan will help identify weaknesses early, track compliance performance and provide management with evidence that important controls are working as expected. Since the company handles sensitive customer information, particular attention will be given to data protection, access management, employee awareness, security incidents and third-party compliance.

Monitoring Activity	What Will Be Monitored	Frequency	Responsible Party	How Results Will Be Documented
User Access Review	Review user accounts and permissions to confirm that access is appropriate and former employees' accounts have been removed.	Monthly	IT Manager	Access review report and system logs
Data Protection Compliance Review	Check how personal data is collected, stored, accessed and shared to ensure GDPR and privacy requirements are followed.	Quarterly	Compliance Officer / Data Protection Officer	Privacy compliance checklist and review report
Security Awareness Training	Monitor whether employee's complete mandatory compliance, privacy and	Quarterly	HR & Compliance Officer	Training attendance and completion records

	cybersecurity training.			
Security and Compliance Incident Review	Review reported incidents, policy violations and data breaches to identify trends and ensure corrective actions are completed.	Monthly	Compliance Officer & Information Security Manager	Incident register and corrective-action tracker
Third-Party Compliance Review	Assess key vendors that process or access sensitive customer information and confirm that contractual security and privacy requirements are being followed.	Annually and before onboarding critical vendors	Procurement & Compliance Officer	Vendor assessment reports, contracts and due-diligence records
ISO/IEC 27001 Control Review	Check whether important information security controls are implemented and operating effectively.	Quarterly	Information Security Manager	Control-testing reports, audit evidence and corrective-action records

The results of these monitoring activities should be reported to management, particularly where significant weaknesses or repeated compliance failures are identified. Any issue found should have a clear owner, corrective action and target date for resolution. In my view, this makes compliance monitoring more useful because management can see not only where the organisation is failing but also what is being done to correct the problem.

3. Design a Compliance Incident Response Procedure that outlines the steps to be taken when a potential compliance violation is identified. Include at least 6 steps with brief descriptions of each. (10 points)

Based on what i have learned, compliance incidents need to be handled quickly and consistently because delays can increase legal, financial and reputational impact. At TechSecure Solutions, employees should know how to report a suspected violation, while management should have a clear process for investigating the issue and taking appropriate action.

Step	Action	Description
1. Identify and Report	Report the suspected violation	Any employee who identifies a possible compliance violation should report it immediately to their manager, the Compliance Officer or through the approved reporting channel.
2. Record the Incident	Document the initial information	The Compliance Officer should record the incident in the compliance incident register, including the date, people involved, systems or data affected and a brief description of what happened.
3. Assess and classify	Determine severity and potential impact	The incident should be assessed to determine its seriousness, including possible legal, privacy, security, financial and reputational impact. High-risk incidents should be escalated to senior management immediately.
4. Contain the Issue	Prevent further impact	Working with relevant teams such as IT or Information Security, immediate measures should be taken to stop the violation from continuing. For example, a compromised account may be disabled or access to exposed information restricted.
5. Investigate	Determine what happened and why	The Compliance Officer should coordinate an investigation by reviewing relevant evidence such as system logs, emails, policies, access records and interviews to identify the root cause of the incident.
6. Escalate and notify	Inform appropriate stakeholders	Management, Legal, the Data Protection Officer and other relevant parties should be informed based on the severity of the incident. Where required by applicable regulations such as GDPR, the organisation should also assess whether regulators or affected individuals need to be notified.
7. Correct and remediate	Address the identified weakness	Corrective actions should be assigned to clear owners with target completion dates. Actions may include updating procedures, changing access permissions, improving technical controls or providing additional employee training.
8. Review and Close	Confirm resolution and capture lessons learned	Before closing the incident, the Compliance Officer should confirm that corrective actions have been completed. Lessons learned should be documented and used to improve policies, controls and future compliance monitoring.

In my view, the most important part of this process is ensuring that an incident does not simply end when the immediate problem is fixed. Understanding the root cause and following up on corrective actions helps prevent the same compliance failure from happening again. It also provides documented evidence that TechSecure Solutions responded appropriately and supports continuous improvement of the compliance programme.

Part 2: Compliance Metrics and KPIs (25 points)

Effective compliance management requires measuring and reporting on key metrics. For this exercise, you will develop a set of compliance metrics and KPIs for TechSecure Solutions.

1. Identify and describe five key compliance metrics or KPIs that TechSecure Solutions should track. For each metric, explain what it measures, why it's important, how it should be calculated, and what the target or benchmark should be. (15 points)

Compliance cannot be managed effectively if an organisation does not measure its performance. Having clear compliance metrics and KPIs helps management understand whether controls are working, where weaknesses exist and whether corrective actions are being completed. For TechSecure Solutions, I would monitor the following five key compliance metrics.

Compliance KPI	What it Measures	Why it is Important	How it is Calculated	Target / Benchmark
1. Compliance Training Completion Rate	The percentage of employees who complete required compliance, privacy and security training within the required period.	Employees need to understand their compliance responsibilities, especially when handling sensitive customer information.	$(\text{Employees who completed training} \div \text{Employees required to complete training}) \times 100$	100% completion
2. Access Review Completion Rate	The percentage of scheduled user access reviews completed on time.	Regular access reviews help identify unnecessary or inappropriate access and reduce the risk of unauthorised access to sensitive information.	$(\text{Access reviews completed on time} \div \text{Total scheduled access reviews}) \times 100$	100% completed on time
3. Compliance Incident	The percentage of identified compliance	This shows whether the organisation responds effectively to	$(\text{Incidents resolved within target time} \div$	≥ 95%

Resolution Rate	incidents that are investigated and resolved within the agreed timeframe.	compliance violations and prevents issues from remaining unresolved.	Total incidents) × 100	
4. Corrective Action Closure Rate	The percentage of corrective actions from audits, incidents and compliance reviews that are completed by their due dates.	Outstanding corrective actions can leave the organisation exposed to risks that have already been identified.	(Corrective actions closed on time ÷ Total corrective actions due) × 100	≥ 95%
5. Third-Party Compliance Assessment Rate	The percentage of critical vendors that have completed required security, privacy and compliance assessments.	TechSecure Solutions may share sensitive information with vendors, so third-party compliance needs to be monitored to reduce supply-chain and data protection risks.	(Critical vendors assessed ÷ Total critical vendors) × 100	100% of critical vendors

These KPIs provide management with a clear picture of how the compliance programme is performing. For example, a low training completion rate could show that employees may not fully understand their compliance responsibilities, while overdue corrective actions could indicate that known risks are not being addressed quickly enough.

So, compliance metrics should not only be collected for reporting purposes. Management should use the results to make decisions and act. If a KPI falls below its target, As the Compliance Officer i should be identifying the cause, assign corrective actions and follow up until performance improves. This makes compliance monitoring an ongoing process rather than something that is only considered when an audit or incident occurs.

2. Design a mock-up of a quarterly compliance dashboard that would be presented to the executive team. Describe what information would be included, how it would be visualized, and why this information is valuable for executive decision-making. (10 points)

For TechSecure Solutions, I would design the quarterly compliance dashboard to give the executive team a simple view of the organisation's compliance position. The dashboard should not contain too much technical information because management mainly needs to see what is working, what is below target and where action or additional resources are required.

Mock Quarterly Compliance Dashboard

Compliance KPI	Target	Current Performance	Status	Management Action
Compliance Training Completion	100%	96%	Amber	Follow up with employees who have not completed training
Access Reviews Completed on Time	100%	90%	Amber	Complete outstanding reviews and identify reasons for delays
Compliance Incidents Resolved on Time	≥95%	97%	Green	Continue monitoring
Corrective Actions Closed on Time	≥95%	82%	Red	Escalate overdue actions to responsible managers
Critical Vendor Assessments Completed	100%	88%	Red	Prioritise outstanding vendor assessments

Dashboard Visualisation

I would use a simple Red, Amber and Green (RAG) status system so that executives can quickly understand the compliance position.

- Green would show that the KPI has achieved or exceeded its target.
- Amber would show that performance is close to the target but requires monitoring or improvement.
- Red would indicate that performance is below the acceptable level and requires management attention.

I would also include a bar chart comparing the target against current performance for the five compliance KPIs. This would make it easier for management to identify gaps without having to analyse detailed compliance reports.

Another section of the dashboard would show the number of compliance incidents reported during the quarter, how many have been closed, any significant audit findings and the number of overdue corrective actions. A simple trend chart could also compare the current quarter with previous quarters to show whether the compliance programme is improving or declining.

Value to Executive Management

The dashboard would be valuable because it converts detailed compliance information into something management can quickly understand and act on. For example, the mock dashboard

shows that only 82% of corrective actions were completed on time against a target of at least 95%. This should receive management attention because unresolved findings may leave known compliance and security risks within the organisation.

In Conclusion, a good compliance dashboard should not only show whether the organisation is compliant. It should help management ask the right questions, assign accountability and make decisions where performance is below the expected level.

Part 3: Compliance Audit Preparation (25 points)

TechSecure Solutions is preparing for an ISO 27001 certification audit in three months. As the Compliance Officer, you need to prepare the organization for this important audit.

1. Create a pre-audit checklist with at least 10 specific items that should be reviewed or prepared before the ISO 27001 audit. For each item, briefly explain its importance to the audit process. (15 points)

1. ISO/IEC 27001 Pre-Audit Checklist

Preparing for an ISO/IEC 27001 certification audit requires more than having information security policies in place. TechSecure Solutions needs to demonstrate that its Information Security Management System (ISMS) is implemented, responsibilities are understood, risks are being managed and there is evidence that controls are operating. Since the audit is only three months away, I would use the following checklist to identify any gaps that need to be addressed before the certification audit.

No.	Pre-Audit Checklist Item	What Should Be Reviewed or Prepared	Why It Is Important
1	ISMS Scope	Confirm and document which business units, systems, locations, processes and information are included within the ISMS.	A clear scope helps the auditor understand the boundaries of the ISMS and what is covered by the certification.
2	Information Security Policies	Review information security policies to ensure they are current, approved by management and communicated to employees.	Policies demonstrate management's expectations and provide direction for information security practices.
3	Information Security Risk	Review the risk register, risk assessment methodology, risk	ISO/IEC 27001 requires the organisation to identify and

	Assessment	owners and current risk ratings.	assess information security risks systematically.
4	Risk Treatment Plan	Confirm that identified risks have appropriate treatment actions, responsible owners and target completion dates.	This demonstrates that risks are not only identified but are actively being managed.
5	Statement of Applicability (SoA)	Review the Statement of Applicability and ensure selected and excluded controls are properly justified.	The SoA is an important audit document because it shows which information security controls apply to the organisation and why.
6	Access Control Records	Review user accounts, privileged access, access approvals and records of terminated employees.	This provides evidence that access to sensitive information and systems is appropriately controlled.
7	Security Awareness and Training	Confirm that employees have completed required information security and compliance training and that records are available.	Auditors need evidence that employees understand their information security responsibilities.
8	Incident Management	Review the incident response procedure, incident register and evidence showing how previous security incidents were handled.	This demonstrates that the organisation can identify, respond to and learn from information security incidents.
9	Supplier and Third-Party Security	Review vendor assessments, contracts and security requirements for third parties that access company or customer information.	Third parties can introduce security risks, so the organisation needs to demonstrate that these risks are being managed.
10	Internal Audit	Confirm that an internal ISMS audit has been completed and identified findings have been documented and followed up.	Internal audits help identify weaknesses before the external certification audit and are an important part of evaluating the ISMS.
11	Management Review	Confirm that management has reviewed ISMS performance, risks, incidents, audit findings and improvement opportunities.	This provides evidence that senior management is actively involved in the ISMS and information security governance.
12	Corrective	Review open findings from	Unresolved findings may indicate

	Actions	audits, incidents and compliance reviews and confirm that corrective actions are being tracked.	that known weaknesses are not being addressed effectively.
--	---------	---	--

Preparation Approach

With only three months remaining before the certification audit, I would not wait until the final weeks to collect evidence. During the first month, I would review the ISMS documentation, risk assessment, Statement of Applicability and policies to identify any major gaps. The second month would focus more on testing controls, reviewing evidence and closing identified weaknesses. During the final month, I would conduct a readiness review or mock audit to confirm that employees understand their responsibilities and that supporting evidence is organised and easily available.

One important part of preparing for an ISO/IEC 27001 audit is being able to provide evidence. It is not enough for TechSecure Solutions to say that access reviews, training or risk assessments are being performed. The organisation should be able to provide records such as access review reports, training records, meeting minutes, risk registers and incident reports to demonstrate that its controls are operating.

2. Develop a communication plan for preparing employees for the upcoming audit. Include at least three different communication methods, the key messages for each, target audience, and timing. (10 points)

Preparing employees for the ISO/IEC 27001 certification audit is important because the auditor may speak to employees from different departments to understand whether information security policies are understood and followed in practice. I would therefore start communication early rather than waiting until a few days before the audit. The aim would be to make employees aware of the audit, remind them of their security responsibilities and make sure they know where to find relevant policies and procedures.

Communication Method	Target Audience	Key Message	Timing
Company-wide Email Announcement	All employees	Inform employees about the upcoming ISO/IEC 27001 certification audit, why the organisation is pursuing certification and everyone's responsibility in supporting information security.	Three months before the audit
Security Awareness Training /	All employees	Refresh employees on important areas such as password security, phishing, data protection, incident reporting,	Two months before the

Workshop		acceptable use and handling sensitive information.	audit
Departmental Meetings	Department managers and their teams	Discuss controls and procedures that apply specifically to each department and confirm that employees understand their responsibilities.	One month before the audit
Management Briefing	Senior management and department heads	Provide an update on audit readiness, major gaps, outstanding corrective actions and areas requiring management support.	Monthly until the audit
Final Audit Readiness Reminder	All employees	Remind employees of the audit dates, how to respond if interviewed by an auditor, where policies are located and who to contact if they have questions.	One week before the audit

Key Communication Approach

The communication should make it clear that employees are not expected to memorise ISO/IEC 27001 requirements. Instead, they should understand the policies and procedures that relate to their work and be able to explain how they apply them in their daily activities.

For example, an employee who handles customer information should understand how that information should be protected, while an IT employee should understand procedures relating to access management, system changes, backups or incident response.

I would also encourage employees to answer audit questions based on what they know and do rather than trying to guess what they think the auditor wants to hear. If employees understand their responsibilities and follow the organisation's procedures consistently, the audit becomes a demonstration of normal working practices rather than something that employees should fear.

In my view, good communication before the audit also helps build a stronger security culture beyond certification. Employees begin to understand that protecting information is part of their everyday responsibility and not something that is only important when an auditor is coming.

Part 4: Compliance Program Evaluation (20 points)

Case Study: FinTech Innovations

FinTech Innovations is a financial technology company that has been in operation for five years. They provide payment processing services and financial management software to small and

medium-sized businesses. The company has grown rapidly from 20 to 150 employees and now serves clients in multiple countries.

The company established a compliance program three years ago when they reached 50 employees. The program consists of:

- A part-time Compliance Officer (who also serves as the Legal Counsel)
- A set of compliance policies that were developed when the program was established
- Annual compliance training for all employees
- Quarterly compliance reports to the executive team
- Ad-hoc compliance monitoring activities

Recently, the company experienced a compliance incident where they failed to update their privacy policies to reflect new regulatory requirements in one of their operating regions. This resulted in a small fine and negative publicity. The CEO has asked for an evaluation of the current compliance program to identify areas for improvement.

Based on this case study, answer the following questions:

1. Evaluate FinTech Innovations' current compliance program using the seven elements of an effective compliance program as a framework. Identify at least three strengths and three weaknesses of their current approach. (10 points)

1. Evaluation of FinTech Innovations' Current Compliance Program

Based on the case study, FinTech Innovations has already taken some important steps towards establishing a compliance programme. However, the recent privacy incident shows that the programme has not developed at the same pace as the organisation. The company has grown from 20 to 150 employees, operates in multiple countries and handles financial and customer information, which means its compliance risks have also increased.

Using the seven elements of an effective compliance programme, I would evaluate the current programme as follows:

Element	Current Position at FinTech Innovations	Assessment
1. Written Policies and Procedures	The company has compliance policies that were developed three years ago when the programme was established.	Weakness: Having documented policies is positive, but they do not appear to be reviewed frequently. The recent privacy incident happened because regulatory changes were not reflected in the company's privacy policies.

2. Compliance Leadership and Oversight	A part-time Compliance Officer manages the programme while also serving as Legal Counsel.	Weakness: Compliance responsibility exists, but combining the Compliance Officer and Legal Counsel roles may limit the time and independence available for proactive compliance management as the company grows.
3. Training and Education	All employees receive annual compliance training.	Strength: Regular training helps employees understand their compliance responsibilities. However, additional role-based or regulatory-change training may be required rather than relying only on annual training.
4. Effective Communication and Reporting Channels	The case does not identify a formal confidential reporting or whistleblowing mechanism.	Weakness: Employees should have clear and confidential channels for reporting suspected compliance concerns without fear of retaliation.
5. Monitoring and Auditing	Compliance monitoring is conducted on an ad-hoc basis.	Weakness: Monitoring should be planned and risk-based. Ad-hoc monitoring increases the possibility that important regulatory changes or control weaknesses will not be identified early.
6. Enforcement and Accountability	There is no clear information about disciplinary procedures or accountability when compliance requirements are not followed.	Needs Improvement: The organisation should clearly define consequences for non-compliance and ensure that standards are applied consistently.
7. Response and Continuous Improvement	Quarterly compliance reports are provided to the executive team, but the recent privacy incident suggests weaknesses in identifying and responding to regulatory changes.	Partial Strength: Reporting to executives is positive because management receives compliance information. However, the programme needs a stronger process for corrective actions, lessons learned and regulatory change management.

Key Strengths

One strength of the current programme is that FinTech Innovations has already established formal compliance policies. This gives the organisation a foundation that can be reviewed and improved rather than having to build a programme from the beginning.

A second strength is the provision of annual compliance training to all employees. This demonstrates that the organisation recognises the importance of employee awareness and understands that employees have responsibilities within the compliance programme.

A third strength is the quarterly reporting of compliance matters to the executive team. Regular reporting gives senior management visibility of compliance activities and provides an opportunity for significant issues to be escalated.

Key Weaknesses

The first major weakness is that the organisation's compliance policies appear to have remained largely unchanged since the programme was established three years ago. The company has grown significantly and expanded into multiple countries, meaning its regulatory environment has also changed. The privacy incident is a clear example of the risk created when policies are not regularly reviewed.

The second weakness is the reliance on a part-time Compliance Officer who also serves as Legal Counsel. This may have been manageable when the organisation had 50 employees, but with 150 employees and operations across several countries, the compliance workload and complexity have increased.

The third major weakness is the use of ad-hoc compliance monitoring. In my view, this is one of the biggest gaps because management cannot wait for an incident to discover that a requirement has changed. Compliance monitoring should be structured, documented and performed according to a defined schedule.

Overall, I would describe the current compliance programme as having a reasonable foundation but needing improvement to match the organisation's current size and risk profile. The recent privacy incident should therefore be treated as an opportunity to strengthen the programme rather than only correcting the privacy policy that caused the immediate problem.

2. Recommend five specific improvements to strengthen FinTech Innovations' compliance program. For each recommendation, explain the rationale and expected benefits. (10 points)

Based on my evaluation, FinTech Innovations needs to improve its compliance programme so that it can support the organisation as it continues to grow and operate in different countries. The recent privacy incident shows that having policies and annual training is not enough if regulatory changes are not identified and acted upon in time. I would recommend the following five improvements.

Recommendation	Rationale	Expected Benefit
1. Establish a Regulatory Change Management Process	The recent incident occurred because the organisation failed to update its privacy policies when regulatory requirements changed. A formal process should be introduced to monitor regulatory developments, assess their impact and assign actions to responsible owners.	The organisation will be able to identify regulatory changes earlier and update policies, controls and business processes before non-compliance occurs.
2. Strengthen the Compliance Function	A part-time Compliance Officer who also works as Legal Counsel may no longer be sufficient for a company with 150 employees operating across multiple countries. Management should consider establishing a dedicated compliance role or providing additional compliance resources.	This will provide more time and resources for monitoring, training, risk assessments and regulatory updates while improving accountability for the compliance programme.
3. Introduce a Risk-Based Compliance Monitoring Plan	Current compliance monitoring is performed on an ad-hoc basis, which increases the possibility that important compliance weaknesses will remain unnoticed. A structured monitoring plan should define what will be monitored, how often, who is responsible and what evidence should be maintained.	Regular monitoring will help identify compliance gaps earlier, provide better evidence for management and allow corrective actions to be taken before problems become serious.
4. Review and Update Compliance Policies Regularly	The current policies were developed three years ago, yet the organisation has grown significantly and expanded into different countries. Policies should be reviewed at least annually and whenever there are major regulatory, business or technology changes.	Policies will remain relevant to the organisation's current operations and regulatory environment, reducing the likelihood of employees following outdated requirements.
5. Improve Training, Reporting and Compliance Awareness	Annual general compliance training is a good starting point, but employees working in areas such as payments, IT, customer data and international operations may face different compliance risks. The organisation should introduce role-based training, regulatory update sessions and clear	Employees will better understand the compliance risks related to their roles, while improved reporting channels will allow potential violations to be identified and escalated earlier.

	confidential reporting channels.	
--	----------------------------------	--

Overall Recommendation

In my submission, FinTech Innovations should move from a compliance programme that mainly reacts to issues towards one that identifies and manages compliance risks before incidents happen. The organisation has grown significantly since the programme was established, so its compliance structure should also grow with the business.

The privacy incident should be used as a lesson for improvement. Management should identify why the regulatory change was missed, update the affected policies and then strengthen the wider regulatory change management process so that the same problem does not happen in another country or regulatory area.

By implementing these recommendations, FinTech Innovations will have clearer accountability, more consistent monitoring, updated policies and better-informed employees. This will reduce the likelihood of future compliance violations while also helping the organisation maintain customer trust and demonstrate to regulators and management that compliance risks are being actively managed.